

Conceitos básicos de segurança da informação

Definições de Risco, ABNT NBR ISO/IEC 27005:2011

Definições de Risco, ABNT NBR ISO/IEC 27005:2011

É válido destacar e definir alguns termos relacionados a gestão de risco:

- **Ativo**
 - Recursos, processos, produtos ou infraestrutura que a organização reconhece como necessitando de proteção.
 - A perda de ativos pode afetar a confidencialidade, integridade ou disponibilidade de informações.

- Seu valor é a soma de todos os aspectos relacionados a ele:
 - Desenvolvimento, manutenção, substituição, credibilidade, custos associados e valor de aquisição.
- **Risco**
 - A probabilidade de uma ameaça explorar uma vulnerabilidade e causar danos a um ativo.

- **Proteção**
 - Implementação de controles ou contramedidas para reduzir os riscos associados a ameaças específicas ou grupos de ameaças.
- **Vulnerabilidade**
 - Ausência ou fraqueza de um sistema em proteção, tornando-o suscetível a ameaças.
 - Ameaças de baixo impacto podem se tornar significativas ou frequente devido a exploração de vulnerabilidades.

- **Invasão**
 - Quando um agente de ameaça obtém acesso a infraestrutura de uma organização ao contornar os controles de segurança estabelecidos, podendo causar danos diretos aos ativos.
- **Exposição**
 - A vulnerabilidade de um ativo a potenciais perdas devido a ameaças.
 - Não significa que há perdas de ativos, apenas que há uma possibilidade de uma vulnerabilidade de ser explorada.

- **Ameaça**
 - Qualquer evento que tenha o potencial de causar efeitos indesejados em uma organização, podendo ser de origem natural ou provocada.
 - Podem ser eventos de baixo ou alto impacto e tudo mais que existe entre as duas possibilidades.
- **Brecha**
 - Quando um mecanismo de segurança é contornado por uma ameaça.
 - Uma brecha explorada junto de um ataque pode significar uma invasão bem-sucedida.